

Ağ Güvenliği ve Tehdit Tespiti Üzerine Bilgilendirme Notu

Yönetici Özeti

Bu bilgilendirme notu, modern siber güvenlik tehditlerinin temel dinamiklerini, tespit yöntemlerini ve bu tehditlere karşı kullanılan temel araçları özetlemektedir. Analizler, ağ altyapısının temel bileşenlerinin (uç noktalar, sunucular, Active Directory) saldırganlar için potansiyel hedefler olduğunu ve bu bileşenlerin güvenliğinin kritik önem taşıdığını ortaya koymaktadır. Etkili bir savunma stratejisinin temel taşı, "savunamayacağınızı göremezsiniz" ilkesiyle özetlenen ağ görünürlüğüdür. Bu görünürlük, hem cihazlarda (host-merkezli) hem de cihazlar arasındaki trafikte (ağ-merkezli) toplanan günlüklerin birleştirilmesiyle sağlanır.

Saldırganlar, ağa sızmak için Ortadaki Adam (MITM) gibi teknikler kullanırken, nihai hedeflerine ulaşmak için genellikle veri sızdırma (Data Exfiltration) yöntemlerine başvururlar. Veri sızdırma, DNS tünelleme, şifrelenmiş HTTP trafiği veya gizli kanallar gibi tespiti zor yöntemlerle gerçekleştirilebilir. Bu tür karmaşık ve gizli faaliyetlerin tespiti, güvenlik duvarlarını aşan tehditleri belirlemek üzere tasarlanmış Saldırı Tespit Sistemleri (IDS) ile mümkündür. IDS'ler, bilinen saldırı kalıplarını (imza tabanlı) veya normal davranıştan sapmaları (anomali tabanlı) tespit ederek güvenlik analistlerine kritik uyarılar sağlar. Snort gibi açık kaynaklı ve kural tabanlı bir Ağ Saldırı Tespit Sistemi (NIDS), bu tehditleri belirlemek için güçlü ve esnek bir araç olarak öne çıkmaktadır.

Ağ Güvenliğinin Temel Unsurları

Kurumsal Ağ Bileşenleri ve Güvenlik Önemi

Bir kurumsal ağ, her biri farklı güvenlik riskleri taşıyan çeşitli bileşenlerden oluşur. Bu bileşenlerin rolünü anlamak, şüpheli aktivitelerin hızlıca tespit edilmesi için kritik öneme sahiptir.

- Kullanıcı İş İstasyonları (Uç Noktalar):** Çalışanların günlük işlerini yürüttüğü PC ve dizüstü bilgisayarlardır. Genellikle **kimlik avı e-postaları veya kötü amaçlı indirmeler yoluyla** saldırganlar için en yaygın giriş noktasıdır. Uç nokta güvenliği, saldırganların ağ içinde yanal olarak hareket etmesini engellemek için ilk savunma hattıdır.
- Dosya ve Veritabanı Sunucuları:** Müşteri kayıtları, finansal veriler ve İK bilgileri gibi bir işletmenin en değerli varlığı olan verileri depolarlar. Saldırganlar genellikle bu sunucuları hedef alır, zira bu sunucuların ele geçirilmesi değerli verilere erişim anlamına gelir. Özellikle **fidye yazılımı (ransomware)** operatörleri, etkilerini en üst düzeye çıkarmak için dosya sunucularını hedef alırlar.

- **Uygulama Sunucuları (Web, E-posta, VPN vb.):** Şirket web siteleri, kurumsal iletişim ve uzaktan erişim gibi hizmetleri sağlarlar. **Dışa dönük (externally facing)** olmaları nedeniyle yüksek değerli hedeflerdir ve saldırganlar tarafından sürekli olarak **yazılım zafiyetleri veya zayıf yapılandırmalar** açısından taranırlar.
- **Active Directory (AD) / Kimlik Doğrulama Sunucuları:** Kurumsal ağların kimlik omurgasıdır. Kullanıcıları, grupları, bilgisayarları ve erişim haklarını yönetir. AD, ayrıcalık yükseltme, kalıcılık sağlama ve yanal hareket için saldırganların yaygın olarak hedef aldığı bir bileşendir. Tek bir **etki alanı yöneticisi (domain admin) hesabının** ele geçirilmesi tüm kurumu tehlikeye atabilir.
- **Yönlendiriciler ve Anahtarlar (Ağ Altyapısı):** Yönlendiriciler, kurumsal LAN'ı internete **bağlarken**, anahtarlar aynı ağ içindeki cihazları birbirine **bağlar**. Ele geçirilmeleri durumunda saldırganlara trafiği engelleme ve manipüle etme (Ortadaki Adam saldırıları), gizli kanallar oluşturma ve arka kapılar yaratma yeteneği sağlarlar.
- **Güvenlik Duvarları / Çevre Cihazları (Firewalls / Perimeter Devices):** Güvenilir iç ağ ile güvenilmeyen internet arasındaki **trafiği kontrol eden** birincil güvenlik kapısıdır. Tanımlanmış güvenlik kurallarına göre gelen ve giden paketlere **izin verir veya engeller**. Günlükleri, port taramaları veya kaba kuvvet denemeleri gibi saldırıların en erken göstergelerini içerir.

Ağ Görünürlüğü: Host ve Ağ Merkezli Günlükler

Siber güvenlikte temel bir ilke şudur: **"Savunamayacağınızı göremezsiniz."** Etkili ağ görünürlüğü, tehdit tespiti ve olay müdahalesi için esastır. Bu görünürlük iki ana günlük kaynağından elde edilir ve bir saldırı zaman çizelgesini oluşturmak için ikisinin de birleştirilmesi gerekir.

- **Host-Merkezli Günlükler (Host-Centric Logs):** Sunucular ve iş istasyonları gibi **ağ üzerindeki bireysel cihazlar (hostlar)** tarafından oluşturulur. Bir sistem üzerindeki saldırının doğrudan etkisini anlamak için gereklidirler.
 - **Ana Kaynaklar:** İşletim Sistemi Günlükleri (Windows Olay Günlükleri, Linux syslog), Uygulama Günlükleri (Apache, Nginx, MSSQL) ve Güvenlik Aracı Günlükleri (Antivirüs, EDR, HIDS).
- **Ağ-Merkezli Günlükler (Network-Centric Logs):** Bir cihazda ne olduğunu değil, **cihazlar arasında** ne olduğunu anlatır. Ağ üzerinde bulunan ve trafiği izleyen ağ cihazları tarafından oluşturulur.
 - **Ana Kaynaklar:** Güvenlik Duvarları (Firewalls), Saldırı Tespit/Önleme Sistemleri (IDS/IPS), Web Proxy'leri ve VPN cihazları. Bu günlükler, bir saldırganın ilk keşif girişimlerini, sistemler arası yanal hareketini veya veri sızdırma denemelerini ortaya çıkarabilir.

Saldırı Tespit Sistemleri (IDS)

Güvenlik duvarları, ağın sınırında trafiği kontrol ederken, bu savunmayı aşan tehditlerin tespit edilmesi için ek mekanizmalara ihtiyaç duyulur. Bir saldırganın meşru görünümlü bir bağlantı yoluyla güvenlik duvarını başarıyla atlaması ve ağ içinde kötü niyetli faaliyetlerde bulunması durumunda, **"bunu zamanında tespit edecek bir şey olmalıdır."** Bu amaçla kullanılan güvenlik çözümü Saldırı Tespit Sistemi (IDS) olarak bilinir.

Dağıtım Modelleri

- **Host Tabanlı IDS (HIDS):** Tek tek ana makinelere kurulur ve yalnızca o ana makineyle ilişkili potansiyel güvenlik tehditlerini tespit etmekten sorumludur. Ana makinenin faaliyetlerine ilişkin ayrıntılı görünürlük sağlar ancak büyük ağlarda yönetimi zordur.
- **Ağ Tabanlı IDS (NIDS):** Belirli ana makinelerden bağımsız olarak tüm ağ içindeki potansiyel kötü niyetli faaliyetleri tespit etmek için kritik öneme sahiptir. Tüm ana makinelerin ağ trafiğini izleyerek merkezi bir görünüm sunar.

Tespit Yöntemleri

- **İmza Tabanlı IDS (Signature-Based IDS):** Her saldırının "**benzersiz bir deseni**" (imzası) vardır. Bu IDS, bilinen saldırı imzalarını veritabanında saklar ve bu imzalarla eşleşen trafiği tespit eder. Bilinen tehditleri tespit etmede verimli olmasına rağmen, "**sıfırinci gün saldırılarını tespit edemez.**"
- **Anomali Tabanlı IDS (Anomaly-Based IDS):** Önce ağın veya sistemin "**normal davranışını**" (temel çizgi - baseline) öğrenir ve bu normal davranıştan herhangi bir sapma olduğunda tespit gerçekleştirir. Sıfırinci gün saldırılarını tespit edebilir ancak meşru aktiviteleri kötü niyetli olarak işaretleyerek "**çok sayıda yanlış pozitif üretebilir.**"
- **Hibrit IDS (Hybrid IDS):** Her iki yaklaşımın güçlü yönlerinden yararlanmak için imza tabanlı ve anomali tabanlı tespit yöntemlerini birleştirir.

Yaygın Saldırı Teknikleri ve Tespit Yöntemleri

Ağ Keşfi (Network Discovery)

Saldırganlar, bir organizasyonun internete açık varlıklarını, yani "**saldırı yüzeyini**" keşfederek saldırılarına başlarlar. Bu aşama, saldırının nereden başlayacağını belirlemek için kritik bilgiler toplar.

- **Reconnaissance (Keşif):** Tarama etkinliği, özel bir ağın dışında bulunan bir IP adresinden geliyorsa, saldırı henüz keşif aşamasındadır.
- **Discovery (İç Keşif):** Tarama etkinliği, 10.x.x.x gibi özel bir IP adresinden, yani içeriden geliyorsa, bu durum ağa çoktan sızıldığını ve saldırının iç ağda bilgi topladığını gösterir.
- **Yatay Tarama (Horizontal Scanning):** Bir saldırganın aynı portu **birden fazla hedef IP adresi** üzerinde taramasıdır. Belirli bir zafiyeti taşıyan tüm makineleri bulmak için kullanılır.
- **Dikey Tarama (Vertical Scanning):** Tek bir ana makine IP adresinin birden fazla port üzerinde taranmasıdır. Değerli bir hedef olarak görülen tek bir makinenin açık hizmetlerini ve potansiyel zafiyetlerini belirlemek için yapılır.

Ortadaki Adam (Man-in-the-Middle - MITM) Saldırıları

MITM saldırısı, "**bir saldırganın iki taraf arasındaki iletişimi gizlice ele geçirdiği ve potansiyel olarak değiştirdiği**" bir siber saldırı türüdür. Bu saldırılar genellikle zayıf şifreleme veya kimlik doğrulama mekanizmalarını hedefler.

ARP Sahtekarlığı (ARP Spoofing)

Bu teknikte saldırgan, kurban cihazları kandırarak saldırganın MAC adresini meşru bir IP adresiyle (genellikle varsayılan ağ geçidi) ilişkilendirmeleri için sahte ARP yanıtları gönderir. ARP protokolünün **kimlik doğrulaması olmaması** bu saldırıyı mümkün kılar.

- **Saldırı Göstergeleri:**
 - **Yinelenen MAC-IP Eşleşmeleri:** Birden fazla MAC adresinin aynı IP adresini talep etmesi.
 - **İstenmeyen ARP Yanıtları:** İlgili istekler olmadan yüksek sayıda ARP yanıtı ("gratuitous ARP").
 - **Anormal ARP Trafik Hacmi:** Kısa aralıklarla çok sayıda ARP paketi.

DNS Sahtekarlığı (DNS Spoofing)

DNS Önbellek Zehirlenmesi olarak da bilinen bu yöntemde saldırgan, kurbanın DNS sorgusunu ele geçirir ve ziyaret edilmek istenen web sitesi için sahte bir IP adresi içeren sahte bir DNS yanıtı gönderir. Bu, kurbanı sahte bir siteye yönlendirir.

- **Saldırı Göstergeleri:**
 - **Aynı Sorgu İçin Birden Fazla DNS Yanıtı:** En güvenilir göstergedir.
 - **Beklenmedik Bir Kaynaktan Gelen DNS Yanıtı:** Yanıt, yapılandırılmış herhangi bir çözümleyiciyle eşleşmeyen bir IP'den gelir.
 - **Şüpheli Derecede Kısa TTL Değerleri:** Saldırganlar, zehirlenmiş kayıtların kısa ömürlü olması için çok düşük TTL (1-30s) değerleri kullanır.

SSL Soyma (SSL Stripping)

Saldırgan, bir istemci ile sunucu arasındaki TLS şifrelemesini kaldırmak veya engellemek için trafiği ele geçirir. Bu, istemcinin HTTPS yerine HTTP üzerinden iletişim kurmasına neden olurken, saldırgan sunucuyla güvenli bir HTTPS oturumunu sürdürür ve aradaki tüm verileri düz metin olarak görür.

- **Saldırı Göstergeleri:**
 - **İlk İstek ve Yanıt Farkı:** Kullanıcının ilk isteği HTTPS (port 443) için olabilir, ancak sonraki paketler aynı alan adı için hemen şifrelenmemiş HTTP'ye (port 80) geçer.
 - **Yönlendirmeler:** HTTPS isteğini sürekli olarak bir HTTP kaynağına yönlendiren HTTP 301 veya 302 durum kodları.

Veri Sızdırma (Data Exfiltration)

Veri sızdırma, hassas verilerin bir bilgisayardan veya cihazdan yetkisiz olarak aktarılmasıdır. Bu, bir ağ ihlal eden saldırganların birincil hedeflerinden biridir.

Sızdırma Aşamaları

1. **Keşif / Toplama (Discovery / Collection):** Saldırgan hassas dosyaları bulur.
2. **Hazırlama / Sıkıştırma (Staging / Compression):** Saldırgan dosyaları bir araya getirir, sıkıştırır, şifreler veya kodlar (ZIP, RAR, base64 vb.).
3. **Sızdırma Aktarımı (Exfiltration Transport):** Ağ, çıkarılabilir medya, bulut veya gizli kanallar üzerinden transfer gerçekleştirilir.
4. **Komuta & Kontrol (C2) Koordinasyonu:** Transferi yönetir ve alımı onaylar.

Sızdırma Teknikleri ve Göstergeleri

Teknik Kategorisi	Örnekler	Saldırı Göstergeleri ve Bakılacak Yerler
Ağ Tabanlı	S3/Azure Blob/webmail'e HTTP/S yüklemeleri, FTP/SFTP/SCP, DNS tünelleme, özel TCP/UDP.	Proxy günlükleri (büyük POST istekleri), güvenlik duvarı akışları (tek IP/ASN'ye yüksek bayt), Netflow (ani artışlar), DNS günlükleri (uzun ana makine adları, TXT sorguları).
Host Tabanlı	Powershell/Invoke-WebRequest, rclone, awscli, curl/wget, arşiv oluşturma (zip/rar), USB kullanımı.	Sysmon/EDR (Process Create, Network Connect, File Create olayları), Windows Güvenlik (4663/4656 nesne erişimi), Linux'ta auditd/shell geçmişi.
Bulut Sızdırması	S3 PutObject / çok parçalı yükleme, Azure Blob yüklemeleri, Drive/SharePoint harici paylaşımı.	CloudTrail / Azure Activity / GCP Audit günlükleri, bulut depolama erişim günlükleri, olağandışı hizmet hesabı veya IP etkinliği.
Gizli ve Kodlama	DNS tünelleme, base64 veya parçalı kodlama, resim/ses dosyalarına steganografi, yavaş ve düşük profilli aktarımlar.	DNS günlükleri, çok sayıda küçük POST içeren proxy günlükleri, kesintili yüklemeler ve şüpheli işlem etkinliğinin korelasyonu.
İç Tehdit ve İşbirliği Araçları	Slack/Teams/Dropbox/Google Drive'a harici kullanıcılara yükleme veya paylaşım.	Denetim günlükleri (paylaşım olayları, dosya indirmeleri), posta sunucusu günlükleri.

Belirli Veri Sızdırma Vektörleri

- **DNS Tünelleme:** Verileri DNS sorgularının/yanıtlarının içine kodlayarak güvenlik duvarlarını ve web proxy'lerini atlatır.

- **Göstergeler:** Özellikle 60–100 karakterden uzun, **uzun alt alan adı etiketleri**; sorgu adında yüksek entropi veya Base64 benzeri desenler; nadir kayıt türleri (TXT, NULL).
- **FTP Üzerinden Sızdırma:** Büyük miktarda veriyi taşımak için FTP protokolünü kullanır.
 - **Göstergeler:** Düz metin kimlik bilgilerini gösteren **USER** ve **PASS** komutları; büyük veya tekrarlanan transferleri gösteren **STOR** (yükleme) ve **RETR** (indirme) komutları.
- **HTTP Üzerinden Sızdırma:** Normal web trafiğiyle karışarak gizlenir.
 - **Göstergeler:** Harici/beklenmedik ana makinelere yapılan alışılmadık derecede büyük HTTP POST istekleri; düşük itibarlı alan adlarına yapılan istekler.
- **ICMP Üzerinden Sızdırma:** Dosyaların kodlanmış parçalarını ICMP yankı (echo) paketlerinin yük kısmına yerleştirir.

Pratik Araçlar: Snort NIDS/NIPS

SNORT, açık kaynaklı, kural tabanlı bir Ağ Saldırı Tespit ve Önleme Sistemi (NIDS/NIPS)'dir. Kötü amaçlı ağ etkinliğini tanımlamaya yardımcı olan bir dizi kural kullanır ve bu kurallara uyan paketleri bularak kullanıcılar için uyarılar oluşturur.

Çalışma Modları ve Parametreleri

Mod	Parametreler	Açıklama
Sniffer Modu	-v, -d, -e, -X, -i	Ağ trafiğini tcpdump gibi dinleyerek paket verilerini, TCP/IP başlıklarını ve tam paket içeriğini konsolda gösterir.
Paket Kaydedici Modu	-l, -K ASCII, -r, -n	Dinlenen paketleri bir günlük dizinine kaydeder. Varsayılan konum /var/log/snort 'tur. -K ASCII ile ASCII formatında kaydeder.
IDS/IPS Modu	-c, -T, -N, -D, -A	Kullanıcı tanımlı kurallara göre trafiği yönetir. -c ile yapılandırma dosyasını belirtir, -A fast ile hızlı uyarı modunu etkinleştirir.
PCAP İnceleme Modu	-r, --pcap-list, --pcap-show	Kaydedilmiş pcap dosyalarını okuyarak kural setine göre trafik istatistikleri ve uyarılar üretir.

Snort Kural Yapısı

Her Snort kuralı bir eylem, protokol, kaynak ve hedef IP/port bilgileri, yön ve seçenekler içerir. `eylem protokol kaynak_ip kaynak_port -> hedef_ip hedef_port (seçenekler)`

- **Aksiyonlar (Actions):**
 - `alert`: Bir uyarı oluşturur ve paketi günlüğe kaydeder.
 - `log`: Paketi günlüğe kaydeder.
 - `drop`: Paketi engeller ve günlüğe kaydeder.
 - `reject`: Paketi engeller, günlüğe kaydeder ve oturumu sonlandırır.
- **Protokol:** `ip`, `tcp`, `udp`, `icmp` gibi protokolleri belirtir.
- **IP ve Port Filtreleme:**
 - Tek IP: `192.168.1.56`
 - CIDR aralığı: `192.168.1.0/24`
 - Hariç tutma: `!192.168.1.0/24`
 - Port aralığı: `1:1024` (1 ile 1024 arası), `:1024` (1024'e kadar), `1025:` (1025'ten büyük veya eşit), `[21,23]` (21 ve 23).
- **Yön (Direction):**
 - `->`: Kaynaktan hedefe akış.
 - `<>`: Çift yönlü akış.